

Analyse Critique du Backend — Projet SafeWalk

Ce document présente une auto-évaluation objective de la partie backend de l'application **SafeWalk**, réalisée dans le cadre de mon examen. Il met en lumière les choix techniques validés, les limites identifiées ainsi que les pistes d'amélioration envisagées.

1. Points forts

- **Sécurité et robustesse de l'authentification :**
 - Mise en place d'une stratégie JWT avec un payload minimal (id, role) pour limiter les risques en cas de compromission.
 - Utilisation d'Argon2id couplé à un *pepper* pour le hachage sécurisé des mots de passe.
 - Validation stricte des données entrantes sur l'ensemble des routes grâce à VineJS.
 - *Cas pratique* : Distinction volontaire des schémas d'entrée (registerSchema sans rôle vs createUserSchema avec rôle) afin d'empêcher l'auto-promotion d'utilisateurs non-administrateurs — faille identifiée, corrigée et re-testée lors de l'audit.
- **Gestion des sessions (Refresh Token) :**
 - Mise en place d'un système combinant un *access token* à courte durée de vie (¹ heure) et un *refresh token* à plus longue durée (⁷ jours) avec un secret séparé, via un point de terminaison dédié (POST /users/refresh).
- **Intégrité des données (Transactions SQL) :**
 - Gestion rigoureuse des transactions avec un client dédié (BEGIN, COMMIT, ROLLBACK et release() dans un bloc finally).
 - Garantie de l'atomicité sur des actions complexes telles que la création d'un signalement (insertion du rapport et vote automatique) ou sa validation par un administrateur (mise à jour et commentaire automatique).
- **Volume et richesse fonctionnelle :**
 - Un CRUD complet implémenté sur **6 tables** (users, report, comment, vote, zone, report_type), dépassant le cahier des charges initial.
- **Optimisation des performances (Pagination) :**
 - Implémentation d'une pagination sur les listes principales (/reports, /users, /comments/report/:id) accompagnée de métadonnées uniformes (total, limit, offset, hasMore).
- **Traçabilité et journalisation :**
 - Persistance des requêtes HTTP (morgan) et des erreurs applicatives dans des fichiers dédiés (logs/access.log, logs/error.log), en complément de la sortie console.
- **Documentation et tests :**
 - Documentation Swagger exhaustive couvrant l'intégralité des ressources et tenue à jour au fil des évolutions.

- Tests d'intégration via Bruno couvrant les cas nominaux et d'erreur (⁴⁰⁰ , ⁴⁰¹ , ⁴⁰³ , ⁴⁰⁴ , ⁴⁰⁹), incluant un CRUD complet sur une route protégée (/users).
- **Gestion géospatiale (PostGIS) :**
 - Exploitation de PostGIS pour les calculs géographiques via la colonne point, sans jamais l'exposer directement sous sa forme brute dans les réponses JSON.

2. Points faibles

- **Gestion stateless du Refresh Token :**
 - L'absence de persistance en base de données empêche la révocation anticipée d'un *refresh token* avant son expiration naturelle (pas de déconnexion forcée côté serveur).
- **Sécurité contre les attaques par force brute :**
 - Absence de limitation du nombre de tentatives de connexion sur la route /users/login (*rate-limiting* non configuré).
- **Absence de tests unitaires :**
 - Bien que les tests d'intégration via Bruno soient complets, la logique interne des modèles ne bénéficie pas de tests unitaires isolés.

3. Pistes d'amélioration (Roadmap future)

1. **Tests unitaires :** Intégrer une suite de tests unitaires (via le module natif node:test) pour isoler la logique métier.
2. **Sécurité applicative :** Ajouter un limiteur de requêtes (*rate-limiter*) sur la route d'authentification.
3. **Persistance des sessions :** Stocker les *refresh tokens* en base de données pour autoriser leur révocation.
4. **Notifications :** Mettre en place un système de notification lors de la modification du statut d'un signalement.

4. Note concernant les bonus

- **Refresh Token JWT :** Implémenté en tant que critère bonus explicite de la grille d'évaluation.

Aucun autre bonus de la liste (HTTPS, mise en ligne, TypeScript, mécanismes d'accélération des réponses ou fonctionnalités supplémentaires validées par l'encadrant) n'a été implémenté à ce stade, l'effort s'étant concentré sur la solidité fonctionnelle et la sécurité de l'architecture.